

Rapport Technique

Google Cloud Skills Boost

Sécurisation des Builds de Conteneurs

Paul Nabti

27 février 2026

1 Objectif du laboratoire

Ce laboratoire Google Cloud Skills Boost a pour objectif d'étudier la sécurisation du processus de construction d'images conteneurisées dans Google Cloud.

Le laboratoire met en évidence les risques liés à la chaîne d'approvisionnement logicielle (*Software Supply Chain*) ainsi que les mécanismes permettant de garantir l'intégrité des images Docker utilisées dans un environnement cloud.

2 Contexte de sécurité

Les conteneurs représentent aujourd'hui un élément central des architectures Cloud Native. Cependant, une image compromise lors de sa phase de build peut entraîner :

- l'exécution de code malveillant,
- une compromission Kubernetes,
- une élévation de privilèges,
- une propagation dans toute l'infrastructure.

La sécurisation du pipeline de build devient donc une étape critique.

3 Utilisation de Cloud Build

Le laboratoire utilise le service Google Cloud Build afin d'automatiser la construction des images.

Exemple de soumission d'un build :

```
gcloud builds submit --tag \
gcr.io/$PROJECT_ID/secure-app
```

Cloud Build permet :

- l'automatisation du build,
- la traçabilité,
- l'exécution dans un environnement isolé.

4 Stockage des images dans Artifact Registry

Les images générées sont stockées dans Artifact Registry.

Création d'un dépôt :

```
gcloud artifacts repositories create secure-repo \
--repository-format=docker \
--location=us-central1
```

- Objectifs sécurité :
- contrôle d'accès IAM,
 - centralisation des images,
 - gestion des versions.

5 Analyse de vulnérabilités

Le laboratoire démontre l'importance du scan automatique des images conteneurisées.

Google Cloud analyse les images afin de détecter :

- dépendances vulnérables,
- bibliothèques obsolètes,
- failles connues (CVE).

Activation du scan :

```
gcloud artifacts repositories update secure-repo \
--location=us-central1 \
--enable-vulnerability-scanning
```

6 Principe de confiance des images

Une image ne doit être déployée que si elle provient d'une source vérifiée.

Le laboratoire introduit le concept de validation d'images :

- signature des builds,
- provenance vérifiée,
- contrôle avant déploiement.

Cela empêche l'exécution d'images non approuvées dans Kubernetes.

7 Intégration avec Kubernetes

Les images sécurisées peuvent ensuite être utilisées dans GKE :

```
kubectl create deployment secure-app \
--image=gcr.io/$PROJECT_ID/secure-app
```

Seules les images validées doivent être autorisées au déploiement.

8 Compréhension personnelle

Ce laboratoire met en évidence que la sécurité Cloud ne concerne pas uniquement l'infrastructure mais également la chaîne de production logicielle.

Les points principaux retenus sont :

- une compromission peut apparaître dès la phase de build,
- la vérification des images est essentielle,
- IAM doit contrôler l'accès aux registres,
- l'automatisation améliore la traçabilité et la sécurité.

9 Conclusion

La sécurisation des builds de conteneurs constitue un élément fondamental du modèle Dev-SecOps.

Google Cloud fournit des mécanismes intégrés permettant :

- la construction sécurisée,
- l'analyse de vulnérabilités,
- la validation des images,
- la protection du déploiement Kubernetes.

Ces mécanismes réduisent significativement les risques liés aux attaques sur la chaîne d'approvisionnement logicielle.